

Senhas e chavesiros

incremente sua segurança



Senhas e chavesiros: incremente sua segurança
By Vitor Mattos



Vitor Mattos



Fotografem, comentem,
twitterem!

@VitorMattosRj



Olá! Estava no Rio Agile?

Sim, foi show! Aliá, achei a sua apresentação a melhor. Parabéns!

Não conhecia a ferramenta até então, eu estava iniciando ainda meus estudos sobre BDD. Achei a palestra muito boa mesmo meu nível no assunto sendo muito introdutório.

Hoje tive a oportunidade de ouvir este grande cara [@VitorMattos](#). Deixo aqui os meus parabéns, foi uma grande palestra, valeu cada minuto e espero ver mais o seu trabalho fera, parabéns !

22:46



4



Gostei muito da sua palestra, eu que sou iniciante não entendia bem a importância do composer, ficou muito claro que ele é muito útil e como implementar, adorei.



Quem sou eu?

Desenvolvedor PHP desde 2003

Amante de opensource

Evangelista PHP

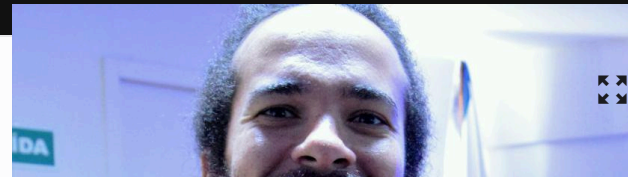
PHP Zend Certified Engineer ([ZEND024235](#))

PHPRio (<https://telegram.me/phprio>)

CTO Lyoon Tech



Redes Sociais: [Facebook](#), [Twitter](#), [LinkedIn](#), [YouTube](#), [Instagram](#)





LYSEONTECH

A Lyseon Tech é uma cooperativa de trabalho com modelo de

gestão democrática, segura e eficiente composta por

profissionais de TI altamente qualificados e experientes no

mercado. Pretendemos apresentar soluções inovadoras



Cronograma

Tentarei ser breve :-D



• Introdução / definições

• Aplicações web



O que é uma senha?

Password



4



O que é secreto?



4



Dados sensíveis



Dados sensíveis

Não versione!

Packagist



Aplicações web

Segurança de

aplicações web



Armazenamento: hash

Definição: *"transformação de uma grande quantidade de dados em uma pequena quantidade de informações"*

Mensagem
Entrada

01010010010101
01010010101010

Saída
Tamanho fixo

--

01010010010101
01010010101010
01010010101010



função
hash



01010101



plain/text, base64, md5, sha1

```
INSERT INTO login (username, password)
VALUES ('admin', '123456');
```

```
mysql_query("INSERT INTO login (username, password)
VALUES ('admin', '".base64_encode('12345678')."')");
```

```
mysql_query("INSERT INTO login (username, password)
```

```
VALUES ('admin', '".base64_encode('12345678')."')");
```

```
mysql_query("INSERT INTO login (username, password)
```



4



Rainbow Table

Definição: *"Uma **rainbow table** é uma tabela de consulta de hashes pré calculados."*



Evitando Rainbow Table



Evitando Rainbow Table



e10adc3949ba59abbe56e057f20f883e



Web Images Videos News

password_hash

Criando hash

```
php > for($i=1;$i<=3;$i++)  
php > echo password_hash("Vitor Mattos", PASSWORD_DEFAULT)."\n"  
$2y$10$iDT0scwr0cP28mb.J0edvOKmmHdGfonvQcnrlQnc6M0BIUoZQ/waW  
$2y$10$Dmfc8Dc9ohV2lKn0jk5IxeHCos6AayVx/vvgz78MuIy9KaxVKuChe  
$2y$10$rVlAfjB3CX8ZmwjCT8boL.Wi8pFMsUZzTkA5XDSsTNbzBa2vvZ3xC
```

Validando hash

```
var_dump(password_verify(  
    "Vitor Mattos",  
    "$2y$10$Dmfc8Dc9ohV2lKn0jk5IxeHCos6AayVx/vvgz78MuIy9KaxVKuChe
```



4



Corrigindo o problema

```
if ($hash == md5($_POST['password'])) {  
    $hash = password_hash(  
        $_POST['password'],  
        PASSWORD_DEFAULT  
    );  
    $db->exec(  

```

```
"UPDATE login SET password = ? WHERE user = ?"
```

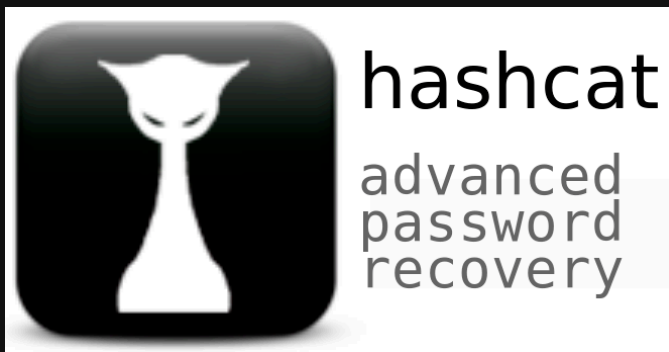
```
);
```

```
}
```



4

Bruteforce



hashcat is the world's fastest and most advanced password recovery tool.

This version combines the previous CPU-based hashcat (now called



released

hashcat-legacy
oclHashcat

MIT



Cluster GPU

25 GPUs
brute force
348 billion
hashes per



Cálculo de complexidade

Entropia: *"média de informação transmitida por um evento, quando se considera todos os resultados possíveis"*



Password length:

Speed: passwords per second

Number of computers:



Bruteforce



☐ PALAVRA-BASE ☐ ORDEM
☐ INCOMUM ☐ DESCONHECIDA

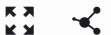
~28 BITS DE ENTROPIA

ERA TROCADOR? NÃO,
ERA TROVADOR. E UM
DOS 0s ERA ZERO?



Bruteforce

Senhas complexas e pequenas só são difíceis de decorar, mas continuam sendo simples de quebrar.



Resolvendo o problema de
bruteforce em aplicações web ...

Segurança de

aplicações web
Vitor Mattos



4



oAuth



4



OAuth

Segurança

*"Facebook hackeado:
ataque atinge 50
milhões de usuários"*



2018.09.28



OAuth

Privacidade



4



2FA, 3FA, 4FA, ..., nFA



4



2FA, 3FA, 4FA, ..., nFA

Quem aceita?

<https://twofactorauth.org/>



4



2FA, 3FA, 4FA, ..., nFA

Token SMS

Victim

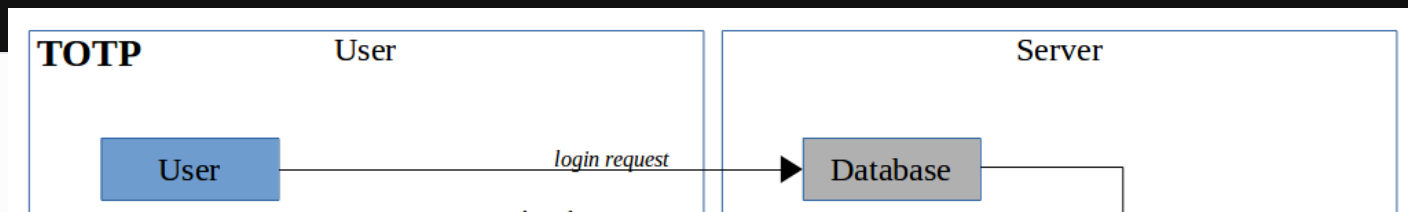
Victim's
Friend

Hacker

2FA, 3FA, 4FA, ..., nFA

TOTP, o que é?

"Time-based One-Time Password algorithm (TOTP)"

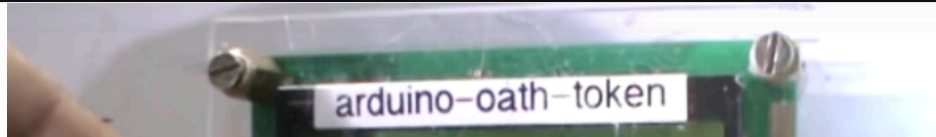


4



2FA, 3FA, 4FA, ..., nFA

Hardware de TOTP



2FA, 3FA, 4FA, ..., nFA

Hardware de TOTP: riscos



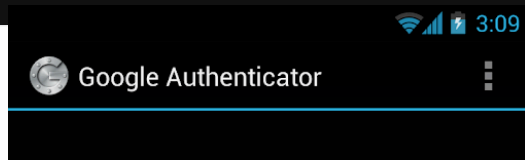
4



2FA, 3FA, 4FA,
..., nFA



TOTP no celular



2FA, 3FA, 4FA, ..., nFA

TOTP no celular: riscos



Prefira sempre HTTPS



HTTP vs HTTPS

Política de senhas



Política de senhas

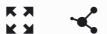
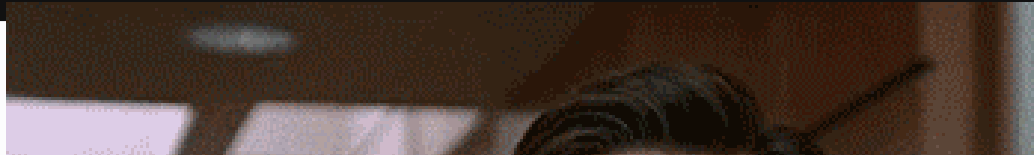
Desculpe, sua senha deve conter uma letra maiúscula, dois números, um símbolo, uma mensagem inspiradora, um feitiço, um sinal de gangue, um

hieróglifo e o sangue de uma virgem.



Política de senhas

Limite máximo



Criando senhas

Vazamento

facebook

Google



last.fm

myspace.com



BANCO

inter

Dropbox

Adobe



Criando senhas

Vazamento: senhas
comuns



The 20 Most Common Keyboard Patterns
in 10 Million Passwords



Criando senhas

Vazamento: toda senha deve ser forte



Criando senhas

trate sua senha como
sua escova de dentes



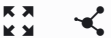
Escolha uma boa
senha e compartilhe



Criando senhas

Evite:

- informações pessoais
- redes sociais revelam senhas
- observadores



Criando senhas

Evite: anotar senhas

A **password** for the **Hawaii** emergency agency was hiding in a public photo, written on a **post-it** note read.bi/2DB4RRz

Criando senhas

Evite: salvar em arquivos abertos

`/*/senhas.txt`

`/*/password.txt`

`/*/senhas.xlsx`



4



Criando senhas

Faça:

- frase

- senhas únicas

- caracteres especiais e aleatórios



4



Senhas geradas por humanos



• baixa entropia

• Memória humana falha



Segurança x Conveniência



Security vs. Convenience



Chaveiros de senhas:

O que são?



Chaveiros de senhas: porque usar?

Senhas grandes - entropia

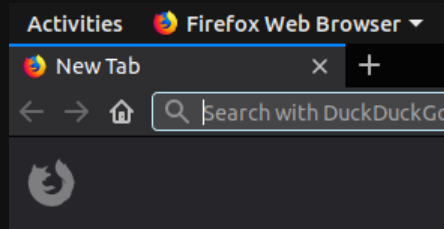
Senhas únicas

Não perder senhas

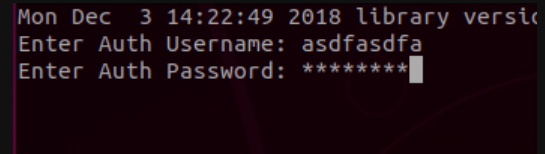
Ocupar a mente com o que é importante



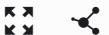
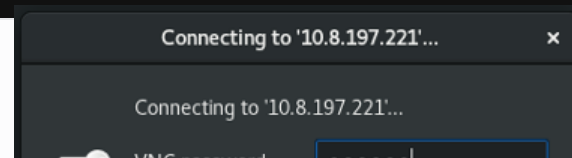
Onde usar?



Navegadores



Terminal



Chaveiros de senhas:

Riscos: Salvar no navegador

- Nem sempre se tem backup
- Extensões maliciosas
- Alguém pode usar seu pc



Chaveiros de senhas:

Riscos: Chaveiro na nuvem



life hacker

VIDEO SKILLET TWO CENTS VITALS OFFSPRING THE UPGRADE APP DIRECTORY

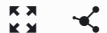


Chaveiros de senhas:

Riscos: Terceiros guardarem suas



senhas
Google e outros serviços de
e-mail online ou aplicativos



OpenSource



4 liberdades do software livre

Liberdade nº 0: A liberdade para executar o programa, para qualquer propósito;

Liberdade nº 1: A liberdade de estudar como o programa funciona, e adaptá-lo para as suas necessidades. Acesso ao código-fonte é um pré-requisito para esta liberdade;

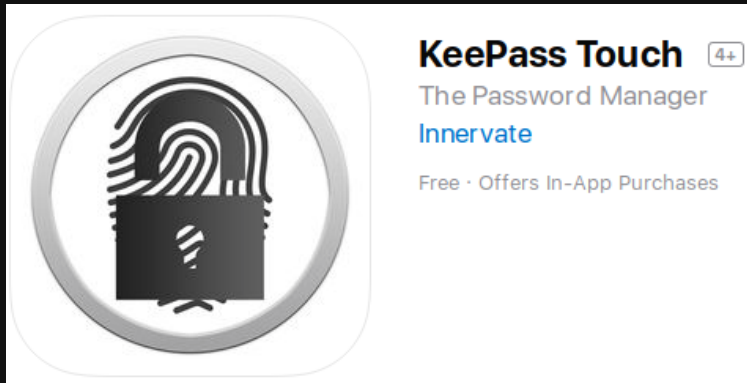
Liberdade nº 2: A liberdade de redistribuir cópias do programa, sem custos;
Liberdade nº 3: A liberdade de modificar o programa e liberar as



4



Chaveiros livres: KeePass



KEEPASSXC

KeePassX

Clientes

KeePass

Primeira versão livre

Escrito em .NET



Emulador

Clientes

KeePassX

Como o nome já diz, cross
platform.



Problema: o projeto está sendo
abandonado, não é mantido por
ninguém.



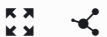
Cientes

KeePassXC

Um fork do KeePassX...

KEEPASSXC

É uma implementação
comunitária, este aceita PR e é
um fork do KeePassX.



Cientes

Celular

Para iPhone, nunca
usei, nem quero usar.



KeepPass Touch 4+

The Password Manager

[Innovate](#)



Cientes

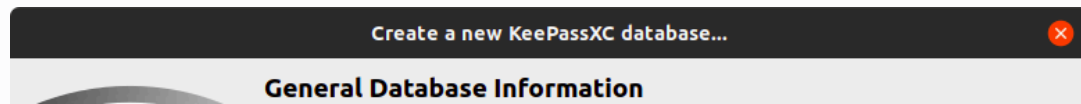
Celular



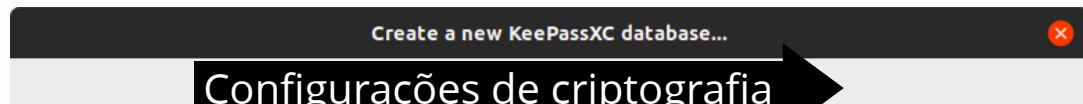
- Interfaz personalizada
- Teclado exclusivo
- Full touch



Criando o primeiro chaveiro



Criando o primeiro chaveiro





Create a new KeePassXC database...



Database Master Key



Senha mestre



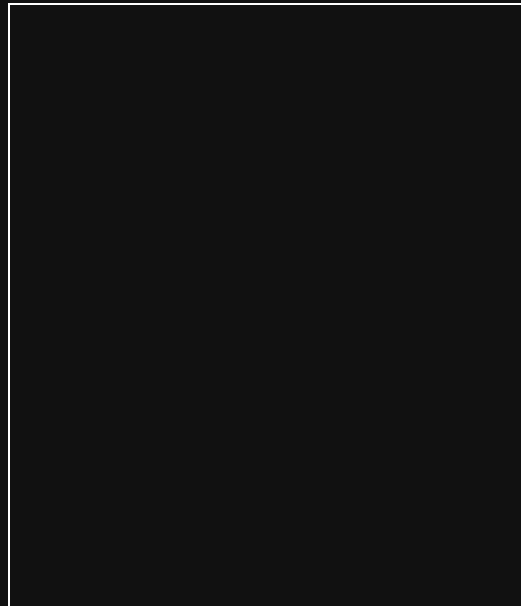
• Tronhe de vez em quando

• Evite palavras fáceis



Senha mestre

Use em computadores
seguros:



Onde salvar?

Sincronismo



Criando a base de dados

Diferentes bases para diferentes fins



• Clientes

• Zonas



Novo registro

O que salvar no
chaveiro?

- Senhas (dãããhh)
- Dados de documentos
- Dados de cartões
- Anotações secretas diversas
- Chaves de SSH
- Outras chaves de autenticação



Novo registro

Geração de senhas



Password: 'Á)>^âx" j îºuîÂY?»báâµ}Ûûúŕô9Ô"¼*\$Æ_ºXKäë¼^k®



Password Quality: Excellent

Entropy: 1926.09 bit



Novo registro

Campos extras



Additional attributes

CVV

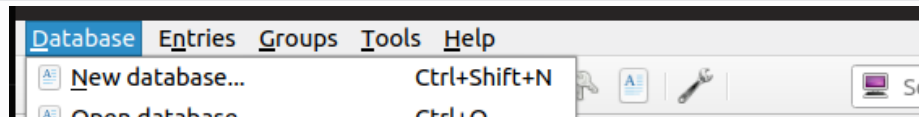
[PROTECTED] Press reveal to view or edit

Add



Novo registro

Importação de senhas



CTRL+SHIFT+V

Autotype

Tecla de atalho



4



Autotype

Tecla de atalho global



Autotype

Tecle de atalho global

Application Settings



General

Basic Settings

Auto-Type

- ☒ Use entry title to match windows for global Auto-Type
- ☒ Use entry URL to match windows for global Auto-Type

Autotype

Sequência configurável

eMail > primary > Edit entry

☒ Enable Auto-Type for this entry

☐ Inherit default Auto-Type sequence from the group

☒ Use custom Auto-Type sequence:



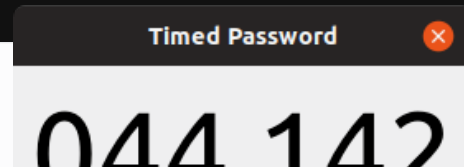
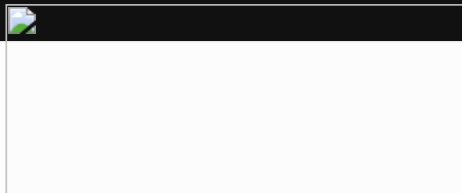
Entry



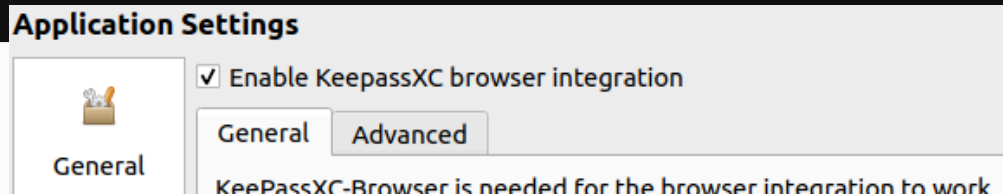
4



TOTP



Integrando com navegador



Integrando com navegador



Settings

Choose own credential fields for this page

Select the login information you would like to get entered into the page:



Integrando com navegador

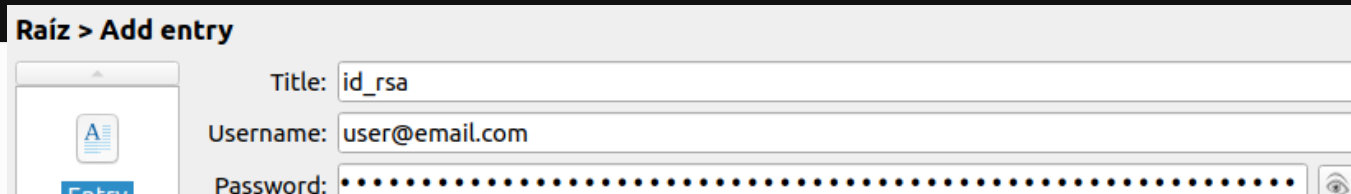
Nas configurações do navegador:

- Desabilitar autocomplete
- Desabilitar de salvar senhas



ssh-agent

1 - Criar uma senha para a chave privada e copiar



Raíz > Add entry

Title:

Username:

Password:

ssh-agent

2 - Gerar uma chave SSH com a senha copiada

```
~$ ssh-keygen -t rsa -b 4096 -o -f id_rsa -C user@email.com
Generating public/private rsa key pair.
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in id_rsa.
Your public key has been saved in id_rsa.pub.
The key fingerprint is:
```

```
SHA256:/0AquhdSloVxKketevMFRknU+UgniQI40xWzZ0v2HHg user@email.com
The key's randomart image is:
+---[RSA 4096]-----+
|  .*00*++ 0          |
| oo.=00* * .         |
| ++ 0* . =          |
```



ssh-agent

2 - Anexar o arquivo id_rsa no KeePass

Raíz > Add entry

Additional attributes

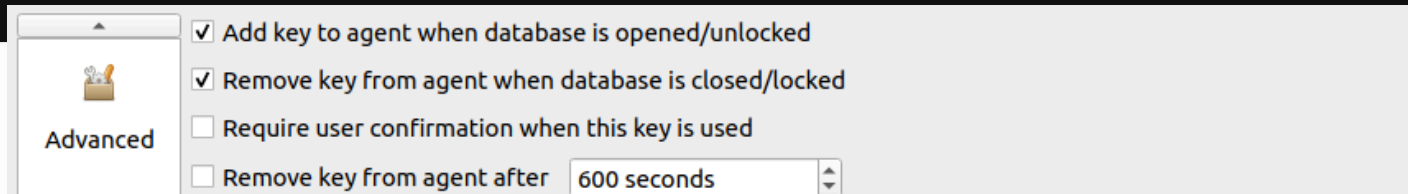
Advanced

Add

Remove

ssh-agent

3 - Informar onde está a chave privada e utilizar a pública



ssh-agent

3 - Informar onde está a chave privada e utilizar a pública

```
~$ ssh-add -l  
4096 SHA256:6hKPtN8/Kb9ZUz12rRwevxHf2qdvJ8x4b6fB3fS2o0k user@email.com (RSA)  
~$ git clone git@github.com:vitormattos/crack-password-calc.git  
Cloning into 'crack-password-calc'...
```

```
remote: Enumerating objects: 67, done.  
remote: Counting objects: 100% (67/67), done.  
remote: Compressing objects: 100% (56/56), done.  
remote: Total 67 (delta 23), reused 0 (delta 0), pack-reused 0
```



4



Temas

1 - Instalar o **qt5ct**

```
sudo apt install qt5ct
```

2 - Exportar a seguinte variável:

OBS: pode colocar no arquivo ~/.profile

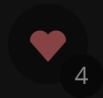
```
export QT_QPA_PLATFORMTHEME="qt5ct"
```

3 - Execute o programa qt5ct e escolha um tema



4

PHP



Packagist *The PHP Package Repository*

[Browse](#)

[Submit](#)



keepass

Packagist is the main [Composer](#) repository. It aggregates public PHP packages Installable with Composer.



Referências

<https://keepassxc.org/>

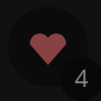
<https://keepass.info/>

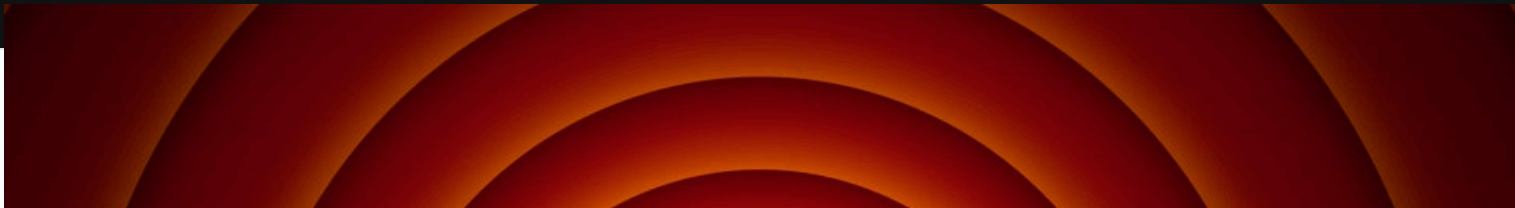
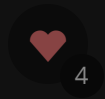
<https://wpengine.com/unmasked/>

https://en.wikipedia.org/wiki/List_of_data_breaches

<https://github.com/hashcat/hashcat>

<https://php.net/password-hash>





Obrigado!

Podem fazer perguntas
durante o evento

Redes sociais:

(VitorMattos ou VitorMattosRJ)

